

Principles of Computer Security, Sixth Edition

Chapter 15 Solutions

Key Terms Quiz

1. spoofing
2. backdoor
3. on-path/man-in-the-middle
4. SYN flood
5. sequence number
6. DNS kiting
7. spyware
8. denial-of-service (DoS) attack
9. birthday attack
10. sniffing

Multiple-Choice Quiz

1. **B.** A SYN flood attack involves launching a large number of SYN packets at a system. In TCP, the response to this is a SYN/ACK, and the system then waits for an ACK to complete the three-way handshake. If no ACK is received, the system will wait until a timeout occurs, and then it will release the connection. If enough SYN packets are received (requesting that communication be set up), the system will fill up and not process any more requests. This is a type of DoS attack.
2. **C.** Sniffing consists of a person simply listening to all traffic on a network. It takes advantage of the friendly nature of the network, in which systems are only supposed to grab and examine packets that are destined to them. Sniffing looks at all packets traveling across the network.
3. **A.** One form of spoofing attack attempts to take advantage of the trusted relationship that may exist between two systems. This trusted relationship could mean that users on one

system will not be required to authenticate themselves when accessing the other system; the second system trusts the first to have performed any necessary authentication. If packets are formed that claim to have come from one of the trusted systems, the target can be fooled into performing actions as if an authorized user had sent them.

4. **C.** This is the description of a replay attack.
5. **D.** Rootkits have almost unlimited power over an infected system. They can cloak themselves from detection and hide their true nature.
6. **C.** This is a description of social engineering. The term *authenticated/white-hat hacking* is often used to refer to authorized penetration tests on a network.
7. **B.** Ransomware is a class of malware that encrypts specific files—preventing them from being used.
8. **C.** To minimize the avenues of attack, you need to limit the information that can be obtained and the number of services you offer. The more services that are available, the greater the number of possible avenues that can be exploited. It is important to install patches, but this doesn't minimize the avenues; it protects specific avenues from attack. The use of firewalls and intrusion detection systems is important, but monitoring them doesn't aid in minimizing the avenues of attack (though a properly administered firewall can help to limit the exposure of your network).
9. **D.** War-driving is an attempt to locate wireless networks whose access area extends into publicly accessible space.
10. **D.** This defines a time bomb. The more general term *logic bomb* is sometimes used, but this term usually refers to a piece of software that is set to execute when some specified event occurs. When that event is a date or time, we often refer to the malicious code as a time bomb.

Essay Quiz

1. Both techniques are used to provide information on what systems are currently accessible. Ping sweeps are used to identify active IP addresses; port scans provide information on active ports and potential applications running on the machine.

2. Two steps should be covered in the student's essay response:

- Use and keep major antivirus software up to date.
- Keep the operating system and all application software patched and up to date.

Lab Projects

Lab Project 15.1

Students should experiment by starting with simple dictionary words and moving up through complex random sequences and see how long it takes password-cracking software to crack passwords. Times will vary from seconds to weeks, depending on machine speed, complexity, and the password cracker chosen. The key is to show how relatively easy it is to crack simple passwords.

Lab Project 15.2

Nmap can be used to scan and map out a local area network. It can also identify the machine's OS and some applications. Students should try these options, but only in a lab environment, not across the Internet from their home ISP.